



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

Bastionado de Redes y Sistemas

TEMA 8

Configuración de dispositivos para la instalación de sistemas informáticos

Alberto Diéguez Álvarez

Contenido

Los directorios que tienen permisos de escritura.	3
Los directorios que tienen permisos de ejecución.	4
Ficheros con el SUID o SGID activado, que permitan ejecutar los ficheros con permisos de root, incluyendo si existe algún fichero con permisos de root entre los de la siguiente lista: https://gtfobins.github.io.....	4
Los ficheros de la variable PATH, comprobando qué usuarios tienen acceso de escritura en esos directorios.	7
Las carpetas compartidas mal configuradas que permiten realizar acciones no controladas.	8
Las particiones que tienen permisos para ejecutar ficheros y otras características que tienen impacto sobre la seguridad.	10
Borrado seguro de archivos.	11

¿Qué te pedimos que hagas?

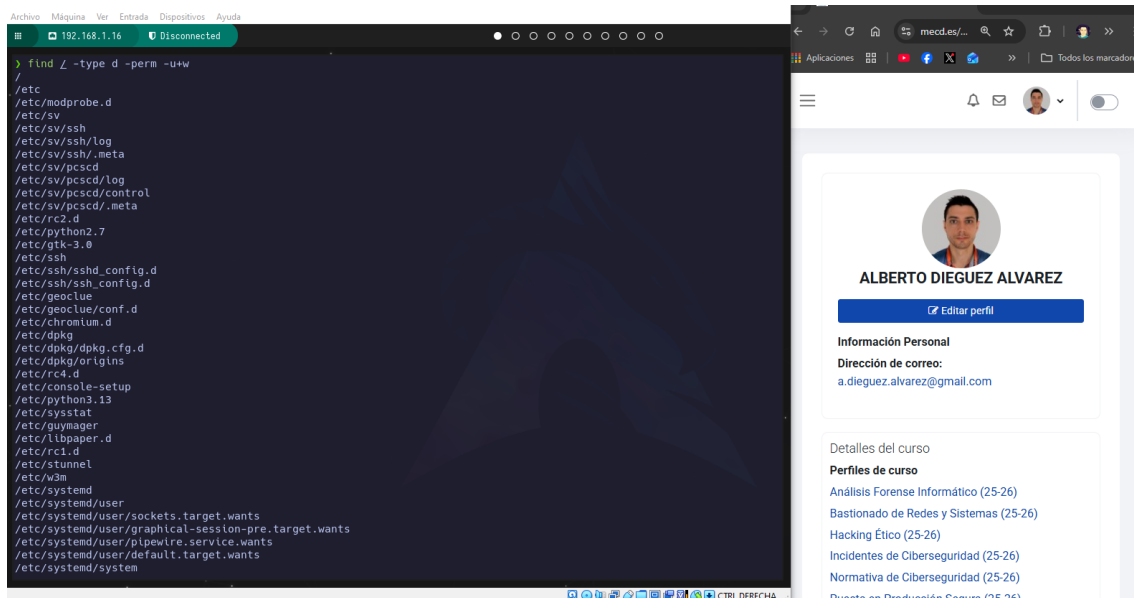
El departamento de I+D tiene unos resultados extraordinarios por lo logros conseguidos en el descubrimiento de un nuevo sistema de propulsión eléctrica en los coches fabricados por la compañía. Existen intereses económicos de empresas de la competencia y actores externos por hacerse con esta información para poder aplicarla a sus modelos.

El CISO de la compañía quiere que se investigue si el sistema donde se guarda la información sensible y crítica es segura. Por lo que ha pedido que se revisen las medidas de seguridad relativas a estos sistemas. Buscando:

Los directorios que tienen permisos de escritura.

Realizo una búsqueda con `find`.

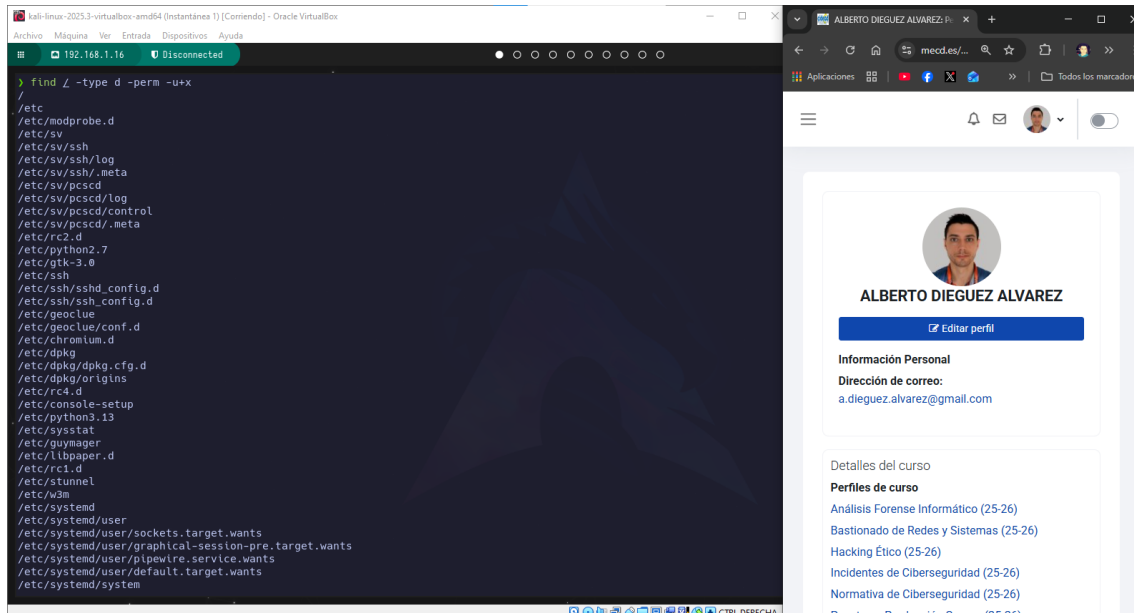
```
find / -type d -perm -u+w
```



Los directorios que tienen permisos de ejecución.

Realizo una búsqueda con `find`.

```
find / -type d -perm -u+x
```

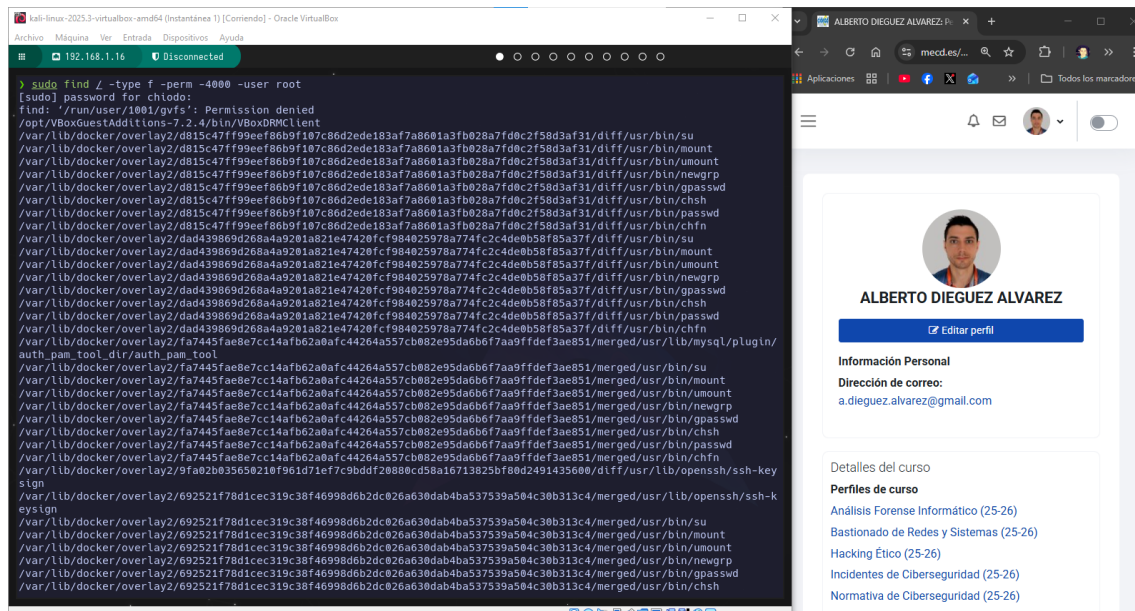


Ficheros con el [SUID](#) o SGID activado, que permitan ejecutar los ficheros con permisos de root, incluyendo si existe algún fichero con permisos de root entre los de la siguiente lista: <https://gtfobins.github.io>

Realizo una búsqueda con `find` y busco los que tienen el SUID o el SGID activados.

```
find / -type f -perm -4000 -user root
```

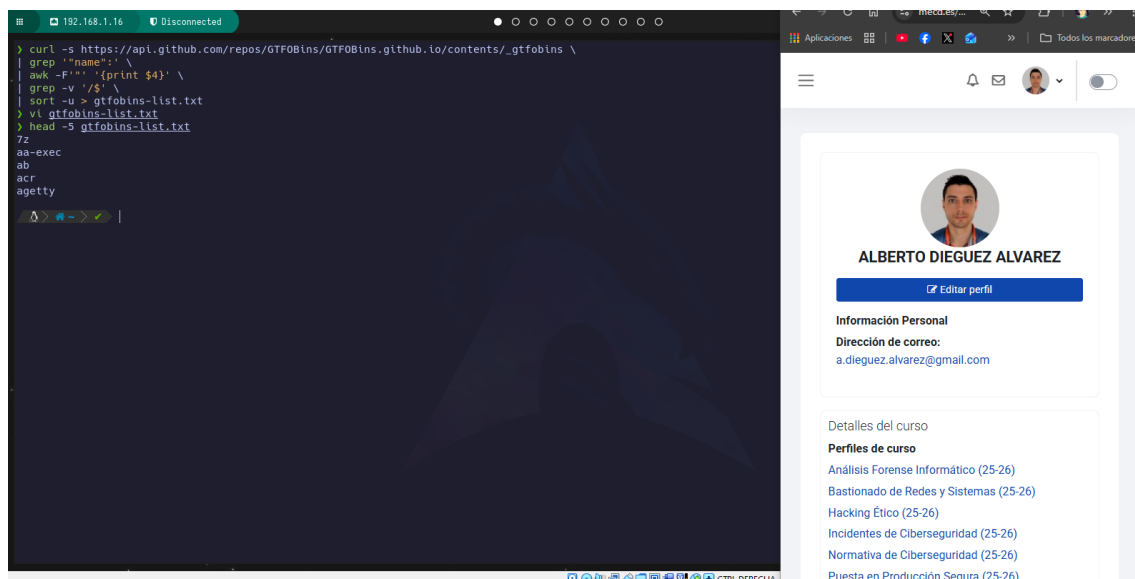
```
find / -type f -perm -2000 -user root
```



Para comprobar los que están en <https://gtfobins.github.io> hago lo siguiente.

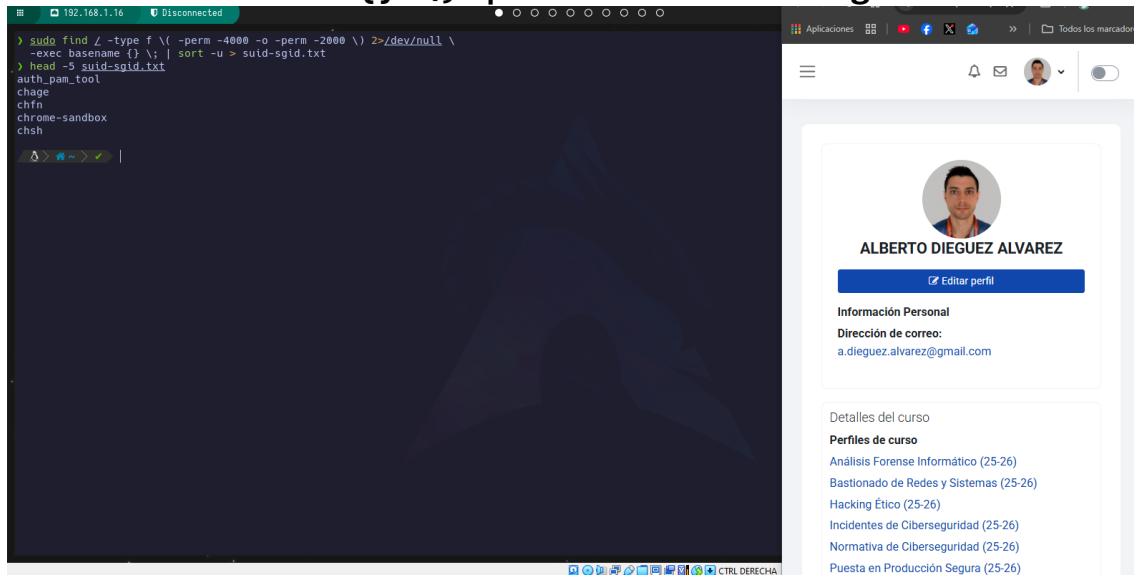
- Primero hago una curl a la lista del repositorio con todos los ejecutables. Y los guardo en una lista.

```
curl -s
https://api.github.com/repos/GTFOBins/GTFOBins.github.io/contents/_gtfobins \
| grep '"name":' \
| awk -F'"' '{print $4}' \
| grep -v '/'$' \
| sort -u > gtfobins-list.txt
```



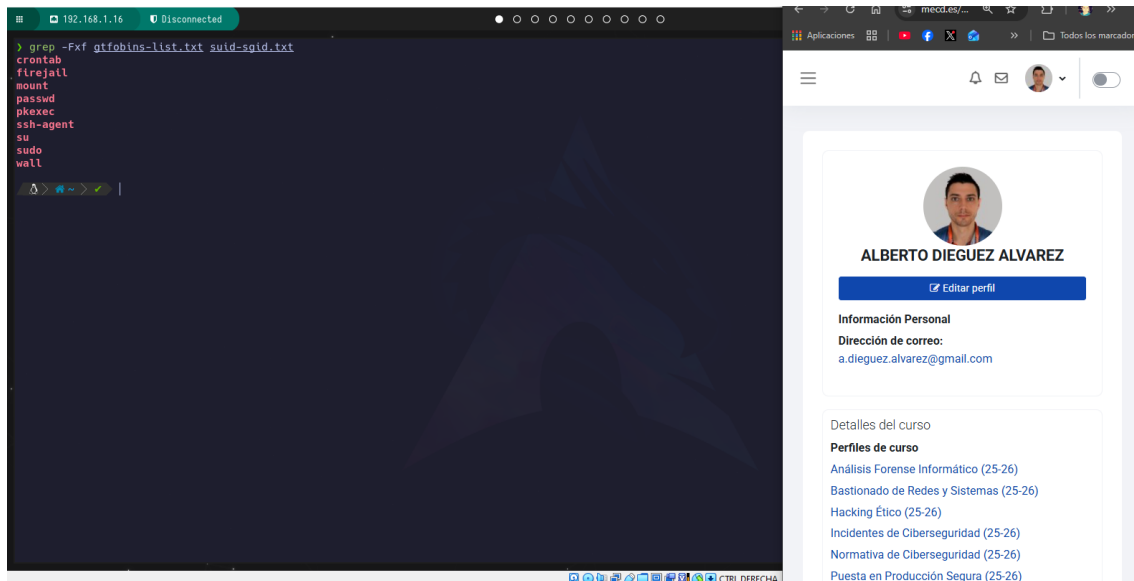
Ahora guardo todos los datos anteriores en un archivo.

```
sudo find / -type f \( -perm -4000 -o -perm -2000 \)
2>/dev/null \
-exec basename {} \; | sort -u > suid-sgid.txt
```



Y ahora busco las coincidencias:

```
grep -Fxf gtfobins-list.txt suid-sgid.txt
```



Los ficheros de la variable PATH, comprobando qué usuarios tienen acceso de escritura en esos directorios.

Después de hacer varias pruebas y buscar alguna forma de hacerlo mas fácil, he decidido hacerlo así, encadenando varios comandos que he ido probando.

```
for d in $(echo $PATH | tr ':' ' ' | sort -u); do
[ -d "$d" ] || continue
perms=$(stat -c "%A" "$d")
owner=$(stat -c "%U" "$d")
group=$(stat -c "%G" "$d")
writable=""
[ -w "$d" ] && writable="(escribible por ti)"
echo "$d : $perms $owner:$group $writable"
done
```

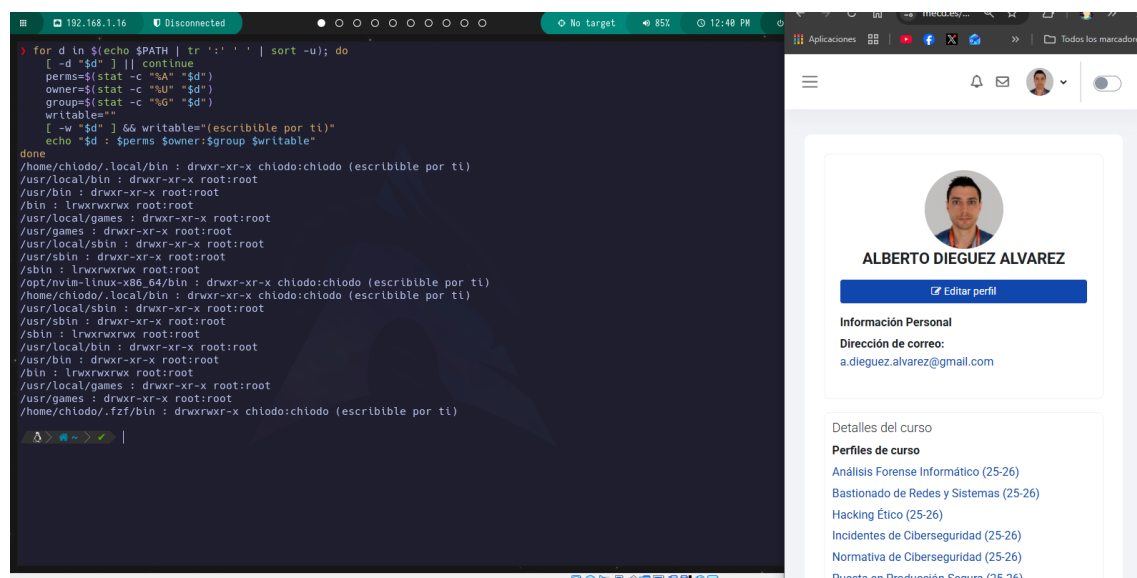
Resumiendo, el script:

Recorremos la variable \$PATH, sustituimos `:` por un salto de línea y eliminamos duplicados.

Luego comprobamos si el directorio existe.

Después con stat podemos ver el estado de archivos del sistema. Buscando en su documentación fue como uso los parámetros que necesito, (stat --help).

Compruebo si el usuario tiene permisos de escritura y si es mi usuario le añado `escribible por ti`. Y por último muestro todo lo recolectado.

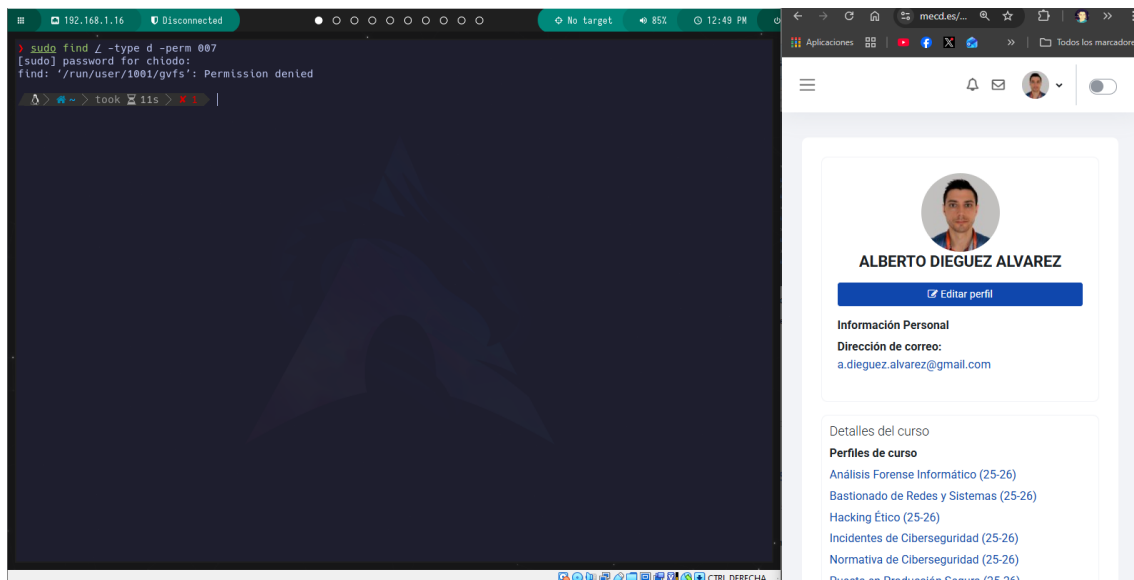


Podemos ver que usuarios tienen permisos de escritura.

Las carpetas compartidas mal configuradas que permiten realizar acciones no controladas.

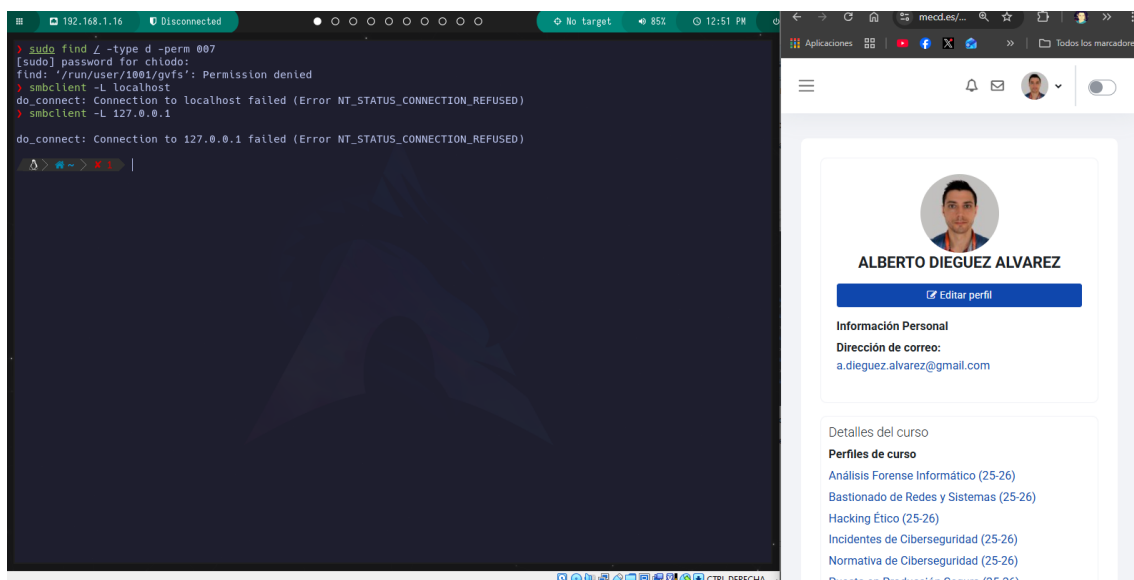
Para ello compruebo los permisos si están mal asignados. No tengo ninguno.

```
find / -type d -perm 007
```



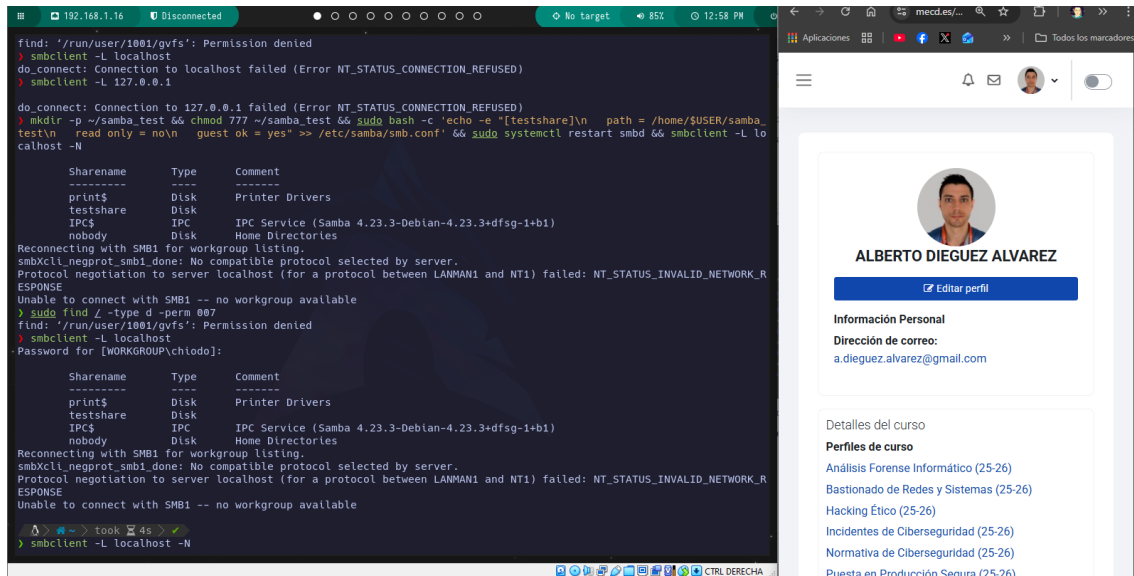
Compruebo los recursos compartidos.

```
smbclient -L localhost
smbclient -L 127.0.0.1
```

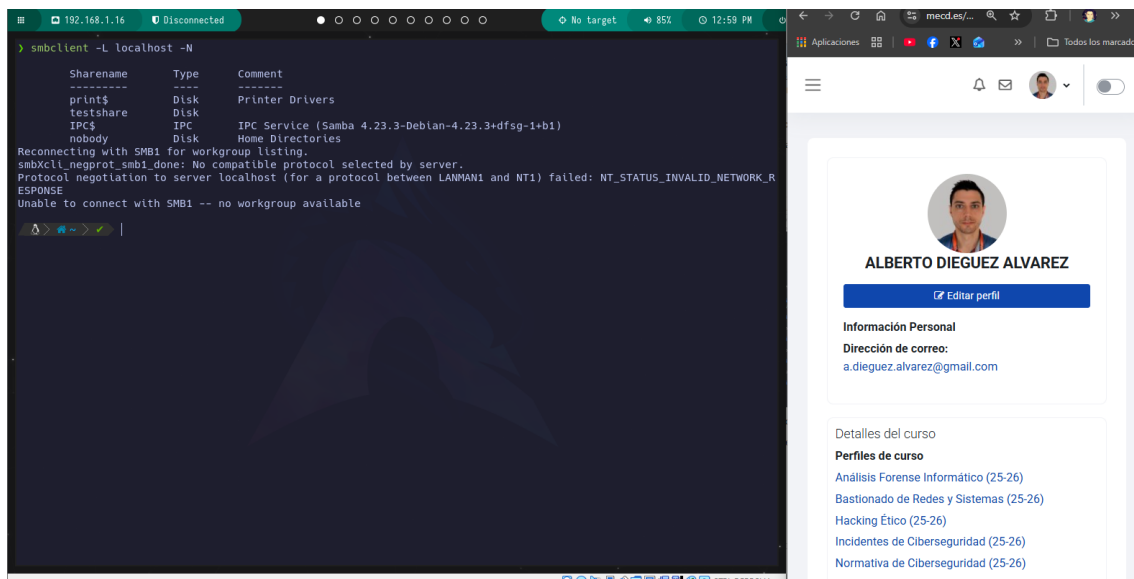


Me creo un recurso de prueba.

```
mkdir -p ~/samba_test && chmod 777 ~/samba_test && sudo  
bash -c 'echo -e "[testshare]\n    path =  
/home/$USER/samba_test\n    read only = no\n    guest ok  
= yes" >> /etc/samba/smb.conf' && sudo systemctl  
restart smbd && smbclient -L localhost -N
```



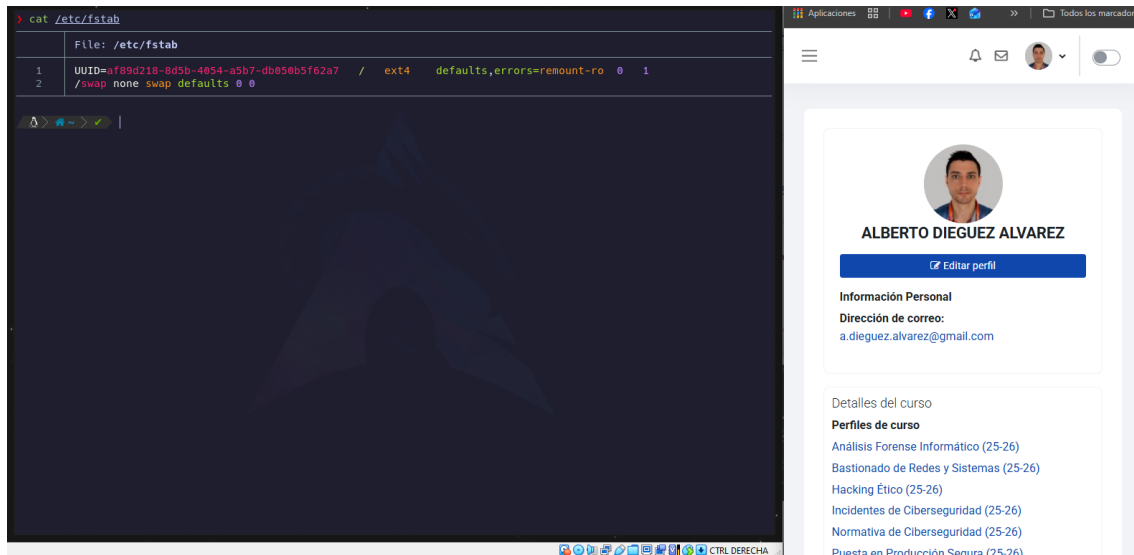
Ahora lo listo.



Las particiones que tienen permisos para ejecutar ficheros y otras características que tienen impacto sobre la seguridad.

Primero busco las particiones que hay:

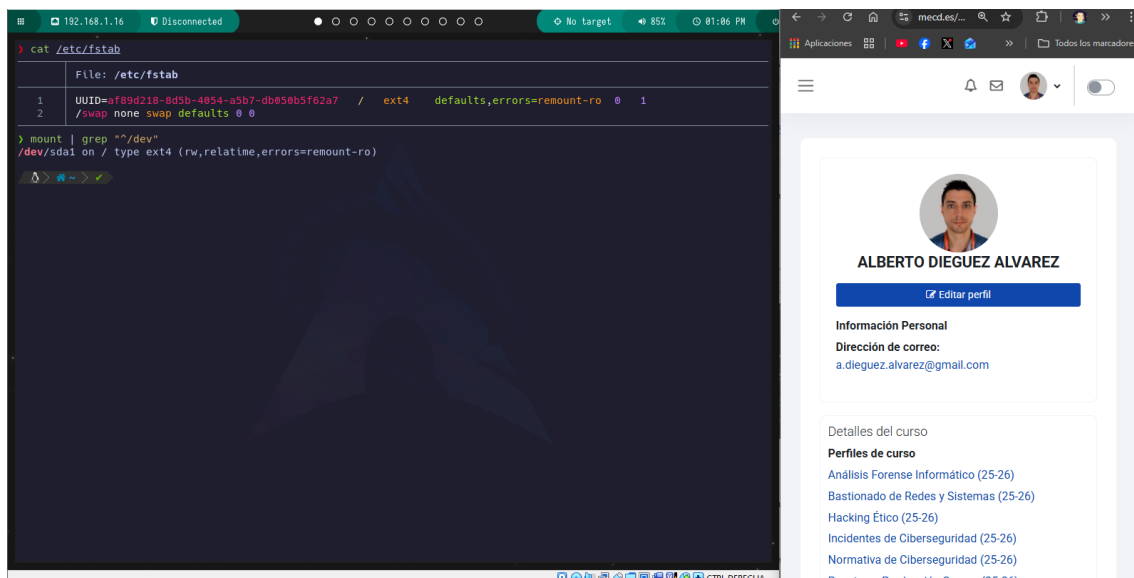
```
cat /etc/fstab
```



```
File: /etc/fstab
1 UUID=af89d218-8d5b-4854-a5b7-db050b5f62a7 / ext4 defaults,errors=remount-ro 0 1
2 /swap none swap defaults 0 0
```

Ahora compruebo permisos.

```
mount | grep "^/dev"
```



```
File: /etc/fstab
1 UUID=af89d218-8d5b-4854-a5b7-db050b5f62a7 / ext4 defaults,errors=remount-ro 0 1
2 /swap none swap defaults 0 0

> mount | grep "^/dev"
/dev/sda1 on / type ext4 (rw,relatime,errors=remount-ro)
```

Como podemos observar nos muestra `rw`, lectura y escritura.

Borrado seguro de archivos.

Para ello usare `shred`:

- z, --zero add a final overwrite with zeros to hide shredding
- f, --force change permissions to allow writing if necessary
- u deallocate and remove file after overwriting

shred -zfu suid-sgid.txt

Tambien usaré wipe en modo recursivo y forzado, que he visto que se usa mucho.

wipe -rf suid-sgid1.txt

